Factory Price Mall

RICT POS System V 1.0

Activity Logging Implementation Design (No-Code Blueprint)

Date: 2026-06-21 Version: 1.0 Status: Planning Document for Future Implementation

---

1. Objectives

1. Capture all high-risk and business-critical user actions.
2. Preserve tamper-evident historical records for audits.
3. Enable fast investigation of operational incidents.
4. Support role-based visibility of logs.
5. Keep logging overhead low enough for concurrent cashier operations.

2. Non-Objectives

1. Replacing existing business tables with event sourcing.
2. Full keystroke or session replay.
3. Logging raw secrets or sensitive credentials.

3. Logging Layers

1. Application Activity Log: Business actions by authenticated users and key system actors.
2. Security Log: Authentication, permission denials, suspicious behavior.
3. System Reliability Log: Queue failures, exceptions, deadlocks, slow requests.
4. Admin Configuration Log: Role/permission changes, pricing changes, company setting updates.

4. Event Naming Standard

Use format: `Domain.Entity.Action`

Examples:

1. auth.user.login_succeeded
2. auth.user.login_failed
3. sales.invoice.created
4. sales.invoice.cancelled
5. purchase.order.created
6. purchase.order.cancelled
7. inventory.stock_adjustment.created
8. inventory.product.quantity_changed
9. cash.reconciliation.submitted
10. cash.reconciliation.approved
11. cash.reconciliation.reopened
12. cash.reconciliation.approval_reversed
13. admin.user.role_assigned
14. admin.permission.denied
15. pricing.product_price.updated

5. Canonical Log Record Schema

Each event should include:

1. event_id
2. occurred_at_utc
3. occurred_at_local
4. request_id (correlation ID)
5. actor_type (human/system/job)
6. actor_id
7. actor_name
8. actor_role
9. action_key
10. module
11. entity_type
12. entity_id
13. business_date (optional)
14. route_name
15. http_method
16. ip_address
17. user_agent
18. status (success/failed/denied)
19. error_code (optional)
20. summary
21. before_values
22. after_values
23. metadata
24. hash_chain_prev (optional)
25. hash_chain_curr (optional)

6. Sensitive Data Policy

Never log:

1. Passwords
2. Password reset tokens
3. API keys and secrets
4. Full card numbers
5. Full OTP codes

Mask in logs:

1. Email: keep first 2 chars + domain only
2. Phone: keep last 4 digits only
3. Address: city and region only
4. Personal notes: redact when flagged sensitive

7. Event Catalog by Module

7.1 Authentication

1. login_succeeded
2. login_failed

3. logout
4. password_changed
5. account_locked
6. session_expired

7.2 Authorization

1. permission_denied
2. role_granted
3. role_revoked
4. permission_granted
5. permission_revoked

7.3 Sales

1. invoice_created
2. invoice_line_added
3. invoice_payment_recorded
4. invoice_cancelled
5. invoice_printed

7.4 Purchase

1. purchase_created
2. purchase_line_added
3. purchase_payment_recorded
4. purchase_cancelled

7.5 Inventory

1. product_created
2. product_updated
3. product_quantity_changed
4. stock_adjustment_created

7.6 Cash Reconciliation

1. reconciliation_created
2. reconciliation_submitted
3. reconciliation_approved
4. reconciliation_reopened
5. reconciliation_approval_reversed

7.7 Pricing and Financial Controls

1. product_cost_updated
2. product_selling_price_updated
3. discount_changed
4. tax_changed

7.8 Administration

1. user_created
2. user_updated
3. user_deactivated
4. company_settings_updated

7.9 Reliability

1. queue_job_failed
2. queue_job_retried
3. exception_thrown
4. deadlock_retried
5. slow_request_detected

8. Minimum Before and After Field Sets

1. Invoice create: invoice_no, customer_id, total_amount, paid_amount, due_amount, created_by.
2. Invoice cancel: status, total_amount, cancelled_by.
3. Product quantity change: quantity and stock_level.
4. Reconciliation approve: status, approved_by, approved_at, variance.
5. Price update: cost_price and selling_price.

9. Storage and Retention Strategy

9.1 Retention Matrix

1. Activity audit records: Hot 90 days, Warm 12 months, Cold 3-5 years.
2. Security logs: Hot 180 days, Warm 18 months, Cold 5 years.
3. Reliability logs: Hot 30 days, Warm 180 days, Cold optional 1 year.
4. Financial control events: Hot 12 months, Warm 24 months, Cold 5-7 years.

9.2 Purge Policy

1. Scheduled purge after archive verification.
2. Purge actions themselves must be logged.

10. Database and Query Design Requirements

1. Append-only audit table writes.
2. No update or delete privileges for normal app roles.
3. Indexes: occurred_at_utc, action_key, actor_id, entity_type+entity_id, status.
4. Optional monthly partitioning for high volume.
5. Export-optimized reporting view.

11. UI Requirements for Activity Logs

11.1 List Columns

1. Time
2. Actor
3. Role
4. Action
5. Module
6. Entity
7. Status
8. IP
9. Request ID

11.2 Filters

1. Date range

2. Actor user
3. Role
4. Module
5. Action key
6. Status
7. Entity type
8. Entity ID
9. IP address
10. Request ID

11.3 Detail Panel

1. Summary
2. Before values
3. After values
4. Metadata
5. Route and method
6. User agent
7. Error code (if failed)

11.4 Export Rules

1. CSV and Excel from filtered result.
2. Role-based export permissions.
3. Export action must be logged (who and when).

12. RBAC for Log Access

1. Super Admin: full access.
2. Manager: business logs only.
3. Supervisor: cash and reconciliation logs only.
4. Cashier: no global access, optional own history only.

13. Alerting Rules

1. 5+ failed logins for one user in 10 minutes.
2. 3+ permission denials for one user in 5 minutes.
3. Invoice cancellation above threshold amount.
4. Any reconciliation approval reversal.
5. Queue failures above threshold per 15 minutes.
6. Repeated deadlock retries above threshold.
7. Price change outside allowed margin window.

14. Incident Investigation Workflow

1. Trigger: alert, complaint, mismatch, escalation.
2. Triage: classify severity within 15 minutes.
3. Evidence: filter by request_id, actor, time range.
4. Correlation: map events across sales, inventory, cash modules.
5. Containment: temporary restrictions if abuse suspected.
6. Root cause: user error, process gap, or system defect.
7. Resolution: business correction + technical fix plan.
8. Post-incident review: lessons and new guardrails.
9. Closure: manager and super admin sign-off.

SLA Targets

1. Critical financial incident: response 15 minutes, containment 60 minutes.
2. High severity incident: response 30 minutes.
3. Medium severity incident: response 4 hours.

15. Performance and Capacity Targets

1. Average log write overhead under 10 ms.
2. P95 log search under 2 seconds for 30-day range.
3. Export up to 100,000 rows via background processing.
4. No noticeable cashier UI lag during invoice save.

16. Phased Rollout Plan

1. Phase 1: Auth, sales create/cancel, inventory quantity changes, reconciliation submit/approve.
2. Phase 2: Admin changes, role/permission changes, pricing updates, denial events.
3. Phase 3: Queue failures, exceptions, deadlock retries, anomaly alerts.
4. Phase 4: Retention automation, archive validation, compliance reporting.

17. Acceptance Criteria

1. All critical actions emit standardized events.
2. Log screen supports required filters and detail panel.
3. Audit entries are append-only and protected.
4. Alert rules trigger correctly in test scenarios.
5. Incident runbook is executable by operations team.
6. Archive and purge cycle completes successfully.
7. Performance targets are met under concurrent cashier load.

18. Decision Points Before Implementation

1. Confirm retention policy by business and legal requirements.
2. Confirm which roles can export logs.
3. Confirm financial thresholds for high-risk alerts.
4. Confirm if hash-chain tamper evidence is mandatory in v1.

Prepared for future implementation in Factory Price Mall, RICT POS System V 1.0. This is a no-code planning artifact.